关于 Apifox 公网 SaaS 版外部 JS 文件受篡改的风险提示与升级公告

原创 Apifox Apifox 2026年3月25日 22:07 广东

致全体 Apifox 用户：

近期我们排查发现，Apifox 公网 SaaS 版桌面客户端动态加载的一个外部 JavaScript 文件遭遇了恶意篡改（遭受供应链攻击）。

如果您在【2026年3月4日】至【2026年3月22日】期间使用了公网 SaaS 版 Apifox 桌面客户端，可能存在敏感信息泄露风险。Apifox 私有化版不受此次事件影响。

攻击者使用的 C2 恶意域名（apifox.it.com）当时托管在 Cloudflare，存活 18 天（2026年3月4日 至 2026年3月22日）。目前该域名已无法访问，没有持续发生恶意行为，我们当前无法复现现场。但是根据部分用户反馈和专业人员分析，被篡改的恶意脚本具有**概率性触发**的特征，触发时可能会读取用户本地设备上的高敏感文件（如 `~/.ssh/`、`~/.zsh_history`、`~/.bash_history`、`~/.git-credentials` 等）。可能会上报到该恶意域名（apifox.it.com）。我们正在联合安全团队持续进行深度溯源。

我们对此起严重的安全事件深表歉意，并已完成紧急修复：

一、 我们的修复方案（已完成） 我们已紧急发布 **2.8.19** 修复版本，并且开启了自动更新提醒。在该版本及后续更新中，我们**已彻底废除该文件的在线动态加载机制，改为本地内置打包**，从物理层面完全切断了此类攻击路径。我们内部已重置所有服务器相关的安全凭证。

二、 请您立即采取的行动（极其重要） 为了保障您的资产安全，我们强烈建议您：

1. **立即升级**： 请尽快将 Apifox 客户端升级至 **2.8.19 或最新版本。**
2. **重置凭证**： 若您在上述风险时间段内使用过受影响版本，请务必联系您的团队，**全面排查并重置**在设备里 `~/.ssh/` 、 `~/.zsh_history` 、 `~/.bash_history` 、 `~/.git-credentials` 等处存储过的敏感凭证（包括但不限于 Git 密钥、鉴权密钥、数据库密码、云服务 Access Key 及环境变量等）。
3. **阻断恶意域名**：apifox.it.com ，可以在 host 文件里增加配置：127.0.0.1 apifox.it.com

三、 本次事件受影响范围： 受影响用户为“**公网 SaaS 版 Apifox 桌面客户端**”用户。SaaS Web 版用户不受影响；私有化部署版用户不受影响。

作为一款开发者工具，安全是我们的底线，我们目前已启动深度的代码审计与溯源调查，以及全面排查和完善我们产品的安全性。

如有任何疑问或需要技术协助，请随时联系我们的安全团队：security@apifox.com。

Apifox 团队
2026年3月25日